



Powered by **Arizona State University**®

Alumno: Luis Alberto Vargas González.

Fecha: 27/05/2026.

Tarea : Unidad 2 A1: Informe y evaluación de riesgos utilizando la metodología MAGERIT.

Maestría en Ciberseguridad.

INDICE.

1. Portada.

2. Introducción.

3. Fundamentos de MAGERIT.

4. Entorno Empresarial.

5. Análisis de riesgos con MAGERIT.

6. Valoración de riesgos y medidas de mitigación.

7. Conclusión.

INTRODUCCIÓN.

En el entorno actual de la ciberseguridad, las instituciones de educación superior que operan bajo un modelo nativo digital enfrentan el desafío de proteger un ecosistema tecnológico dinámico y altamente interconectado. Para la Universidad Digital de las Américas (UDA), cuya operación académica para más de 5,000 estudiantes depende enteramente de plataformas en la nube como el LMS Canvas y sistemas de autenticación unificada (SSO), la seguridad de la información no puede gestionarse de manera empírica o reactiva. Se requiere la adopción de marcos metodológicos estructurados que permitan identificar con precisión el valor de los activos institucionales y el impacto real que sufriría la organización ante incidentes disruptivos.

El presente informe documenta el desarrollo de un análisis y gestión de riesgos informáticos aplicando la metodología MAGERIT (versión 3). La elección de este estándar, promovido por el Consejo Superior de Administración Electrónica de España, responde a su enfoque sistemático y a su capacidad única para modelar las relaciones de dependencia entre los activos técnicos y los procesos de negocio. A través de este documento, se desglosará la fundamentación teórica de MAGERIT, se caracterizará el contexto operativo de la UDA y se presentará una matriz de riesgos detallada con sus respectivas medidas de mitigación organizativas y técnicas, proporcionando una base sólida para la gobernanza de la seguridad en la institución.

FUNDAMENTOS DE MAGERIT.

La metodología MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información) es un marco de referencia ampliamente adoptado a nivel internacional para la gobernanza y auditoría de la seguridad de la información. Su objetivo principal es concienciar a los responsables de las organizaciones sobre la existencia de los riesgos tecnológicos y proveerlos de un método sistemático para gestionarlos a lo largo del tiempo.

MAGERIT se fundamenta en un enfoque de gestión de riesgos que divide el proceso en dos grandes fases: el **Análisis de Riesgos** (comprender qué puede pasar, qué elementos están expuestos y qué valor tienen) y la **Gestión de Riesgos** (implementar y mantener las salvaguardas adecuadas para mitigar dichos riesgos).

Para lograr un análisis estructurado, la metodología se compone de los siguientes elementos clave:

- **Identificación de Activos:** Clasifica los recursos de la organización que tienen valor y que, por lo tanto, requieren protección. A diferencia de otros marcos, MAGERIT destaca por establecer "relaciones de dependencia" entre activos, reconociendo que la caída o degradación de un activo inferior (como un enrutador o un enlace de comunicaciones) impacta de forma directa en un activo superior o de nivel de negocio (como el servicio de clases en línea).
- **Amenazas:** Identifica los eventos o factores de origen natural, técnico, humano (deliberado o accidental) o de salud que pueden desencadenar un impacto negativo en los activos. MAGERIT evalúa las amenazas calculando su tasa de ocurrencia o frecuencia estimada.
- **Vulnerabilidades (o Degradación):** Mide la fracción de valor que pierde un activo cuando una amenaza se materializa con éxito, reflejando qué tan desprotegido o expuesto se encuentra el recurso frente a ese vector de ataque específico.
- **Evaluación del Riesgo:** Calcula el **riesgo intrínseco** (la exposición inicial del activo antes de aplicar medidas de seguridad) y el **riesgo residual** (el nivel de riesgo remanente una vez que se han implementado y validado las salvaguardas o controles defensivos).

ENTORNO EMPRESARIAL.

Para la aplicación práctica de la metodología MAGERIT, se ha seleccionado a la **Universidad Digital de las Américas (UDA)**, un entorno empresarial ficticio que modela con precisión los retos tecnológicos de las instituciones educativas modernas.

a) Caracterización de la Organización y Sector.

- **Sector:** Educación Superior y Tecnología Educativa (EdTech).
- **Tamaño:** Mediana empresa en infraestructura administrativa, pero con alta transaccionalidad digital. Cuenta con una plantilla de 150 empleados administrativos, 300 docentes distribuidos geográficamente y una matrícula activa de 5,000 estudiantes de licenciatura y posgrado.

Operaciones: La UDA opera bajo un **modelo 100% virtual**. No posee campus físicos para la impartición de clases; toda la actividad académica (cátedras sincrónicas, evaluaciones, entrega de tareas) y administrativa (inscripciones, pagos, soporte técnico) se realiza de forma digital las 24 horas del día, los 7 días de la semana.

b) Alcance del Análisis de Riesgos

El alcance de este análisis bajo MAGERIT se acota rigurosamente al **Ecosistema de Aprendizaje Digital y Autenticación**, el cual es el núcleo operativo de la institución. No se incluirán en este alcance los sistemas de marketing externo o recursos humanos presenciales, concentrando el esfuerzo en los activos que garantizan la continuidad de las clases en línea.

c) Clasificación de Activos de Información según MAGERIT

MAGERIT exige categorizar los activos para entender sus dependencias. Para la UDA, se definen los siguientes niveles de activos:

1º[D] Activos de Datos / Información (Nivel Superior):

- *Datos de Identidad:* Credenciales de acceso de alumnos, docentes y administradores.
- *Expediente Académico:* Calificaciones, actas oficiales, historial de entregas y exámenes.
- *Datos Financieros:* Registros de pago de colegiaturas e información de facturación.

2º[S] Servicios (Procesos de Negocio):

- *Servicio de Autenticación Unificada (SSO):* Permite el ingreso único a todo el entorno.
- *Servicio de Gestión de Aprendizaje (LMS Canvas):* Plataforma donde se ejecutan las clases.

3º[SW] Software (Aplicaciones):

- Aplicación web de Canvas (SaaS), APIs de integración para herramientas externas, y software del servidor de autenticación.

4º[HW] Hardware e Infraestructura (Nivel Inferior):

- Infraestructura en la nube (proveedor AWS que aloja el SSO), dispositivos de conectividad perimetral de los administradores de TI, y estaciones de trabajo del equipo de Soporte Técnico.

Factor de Dependencia Relevante: Siguiendo el principio de MAGERIT, el Servicio de clases (LMS) **depende totalmente** del Servicio de Autenticación (SSO), **y este a su vez depende de la integridad del software de la API y de la disponibilidad de la infraestructura en la nube**. Si el hardware o la nube fallan, el impacto se propaga inmediatamente hacia arriba, destruyendo la disponibilidad de los datos académicos.

ANÁLISIS DE RIESGOS.

Siguiendo las directrices de MAGERIT, una vez clasificados los activos, se procede a identificar las amenazas que los acechan y las vulnerabilidades propias de la infraestructura de la UDA, evaluando las dimensiones de seguridad afectadas (Confidencialidad, Integridad y Disponibilidad).

a) Identificación de Activos Críticos y Amenazas Asociadas.

1. Activo: Portal de Autenticación Única (SSO) y API de Conexión

- **Dimensión de Seguridad Principal:** Disponibilidad [D] y Autenticidad [Aut].
- **Amenazas Externas:** Ataques de Denegación de Servicio Distribuido (DDoS) dirigidos a saturar el portal de acceso; ataques de *Phishing* dirigido (*Spear Phishing*) para robar credenciales de administradores.
- **Vulnerabilidades:** Ausencia de un segundo factor de autenticación (MFA) para roles de soporte y falta de un servicio de mitigación DDoS perimetral en la nube.

2. Activo: Base de Datos de Expedientes Académicos y Calificaciones

- **Dimensión de Seguridad Principal:** Integridad [I] y Confidencialidad [C].
- **Amenazas Externas e Internas:** Inyección de código malicioso (SQL Injection) en formularios web; alteración deliberada de datos por parte de usuarios internos con privilegios excesivos; infección por *Ransomware*.
- **Vulnerabilidades:** Falta de sanitización de entradas en el desarrollo de APIs institucionales y ausencia de segregación de funciones en el equipo técnico.

3. Activo: Infraestructura en la Nube (AWS / Repositorio LMS)

- **Dimensión de Seguridad Principal:** Disponibilidad [D].
- **Amenazas Naturales y Técnicas:** Caída sistémica de la región del proveedor de servicios en la nube; errores de configuración por parte del personal operativo.
- **Vulnerabilidades:** Inexistencia de un entorno de recuperación redundante en una región geográfica secundaria (arquitectura de sitio único).

b) Matriz de Riesgos de MAGERIT

Para calcular el nivel de riesgo intrínseco, cruzamos la **Probabilidad de Ocurrencia (Frecuencia de la amenaza)** con el **Impacto Potencial (Degradación del activo)**, utilizando una escala cualitativa estándar: *Baja, Media, Alta y Crítica*.

Código	Activo Evaluado	Amenaza Identificada	Probabilidad	Impacto	Nivel de Riesgo Intrínseco
R-01	SSO / API Acceso	Ataque DDoS masivo	Alta	Alto	Alto
R-02	Base de Datos	Infección por Ransomware	Media	Crítico	Crítico
R-03	Base de Datos	Inyección SQL (Alteración de datos)	Alta	Alto	Alto
R-04	Nube AWS / LMS	Caída del proveedor de nube	Baja	Crítico	Medio
R-05	SSO / API Acceso	Secuestro de cuenta administradora	Media	Crítico	Crítico

Justificación del cálculo: Los riesgos **R-02** y **R-05** se clasifican como **Críticos** debido a que la UDA no cuenta con controles preventivos robustos (como MFA o respaldos inmutables). Al tener una alta dependencia de estos activos, cualquier interrupción o pérdida de integridad detiene por completo la operación de la universidad y destruye la confianza reputacional de manera inmediata.

VALORACIÓN DE RIESGOS Y MEDIDAS DE MITIGACIÓN.

En esta fase, de acuerdo con los lineamientos de MAGERIT, se valoran los riesgos identificados para priorizar de forma estratégica los recursos de la organización. Asimismo, se seleccionan las **salvaguardas** adecuadas (controles técnicos, organizativos y de gestión) para reducir la probabilidad de ocurrencia o mitigar el impacto, calculando finalmente el nivel de riesgo residual.

a) Clasificación y Priorización de Riesgos.

Con base en la matriz de impacto y probabilidad desarrollada, el orden de atención prioritario para mitigar las amenazas en la UDA es el siguiente:

- 1º Prioridad 1 (Crítica):** Riesgo de infección por *Ransomware* en la Base de Datos (**R-02**) y el riesgo de Secuestro de cuentas con privilegios administrativos (**R-05**).
- 2º Prioridad 2 (Alta):** Ataques de Denegación de Servicio Distribuido (DDoS) al portal SSO (**R-01**) e Inyecciones SQL orientadas a la alteración de calificaciones (**R-03**).
- 3º Prioridad 3 (Media):** Caída sistémica de la región del proveedor de infraestructura en la nube (**R-04**).

b) Propuesta de Salvaguardas de Seguridad

Para abordar cada riesgo de manera integral, se definen medidas de mitigación clasificadas según su naturaleza operativa dentro de la institución:

- **Controles Técnicos (Salvaguardas Tecnológicas):**

- *Para R-02 y R-03 (Protección de Base de Datos):* Implementación de un Cortafuegos de Aplicaciones Web (WAF) en el perímetro de las APIs institucionales para bloquear peticiones maliciosas e intentos de inyección de código. Configuración de un esquema de respaldos automatizados, cifrados e inmutables en AWS, aislados lógicamente de la red operativa diaria.
- *Para R-01 (Protección frente a DDoS):* Despliegue de un servicio perimetral de mitigación de denegación de servicio nativo de la nube (como AWS Shield Advanced) para absorber picos de tráfico malicioso antes de que afecten al SSO.
- *Para R-05 (Control de Accesos):* Habilitación obligatoria de un Segundo Factor de Autenticación (MFA) basado en aplicaciones criptográficas de tokens dinámicos para todo el personal con privilegios de administración y docencia.

- **Controles Organizativos (Salvaguardas de Procesos):**

- *Para R-02 y R-05:* Establecimiento formal de una política interna de Gestión de Parches y Actualizaciones Críticas para el software de integración de Canvas. Diseño de un procedimiento estricto para la revocación inmediata de privilegios de acceso al personal técnico o docente que cause baja en la universidad.

- **Controles de Gestión (Gobernanza):**

- *Para R-04 (Resiliencia de Nube):* Revisión y endurecimiento semestral de los Acuerdos de Nivel de Servicio (SLA) con el proveedor de nube y el diseño conceptual de una arquitectura de redundancia multirregión (*Multi-Region Failover*) para los datos institucionales más críticos.

c) Matriz de Riesgo Residual y Viabilidad

Una vez seleccionadas las salvaguardas, se proyecta el **Riesgo Residual**, que representa el nivel de riesgo remanente una vez que los controles defensivos se encuentren operando.

Código	Riesgo Intrínseco	Salvaguarda Principal Propuesta	Viabilidad Económica / Técnica	Riesgo Residual
R-01	Alto	Servicio perimetral de mitigación DDoS	Alta (Inversión económica media)	Bajo
R-02	Crítico	Respaldos inmutables + Aislamiento de red	Alta (Bajo costo, configuración interna)	Bajo
R-03	Alto	Despliegue de WAF + Sanitización de código	Media (Requiere tiempo de desarrollo)	Medio
R-04	Medio	Arquitectura multirregión (AWS Failover)	Baja-Media (Presupuesto elevado)	Bajo
R-05	Crítico	Implementación de MFA Obligatorio	Alta (Bajo costo, alto impacto técnico)	Bajo

Análisis de Viabilidad y Priorización Ejecutiva: Las salvaguardas con mayor efectividad y viabilidad inmediata son el despliegue del **MFA (R-05)** y la configuración de **respaldos inmutables (R-02)**. Ambas soluciones aprovechan características nativas de la infraestructura actual, requiriendo una inversión financiera mínima en comparación con el impacto crítico que logran mitigar; por lo tanto, deben ejecutarse en la Fase 1 del plan de implementación. Por el contrario, la arquitectura multirregión (R-04), aunque altamente efectiva, se programa para una fase posterior debido a su complejidad presupuestal y operativa.

CONCLUSIÓN.

La gestión de riesgos de seguridad de la información ha evolucionado de ser una práctica meramente técnica e improvisada a convertirse en un componente crítico de la gobernanza corporativa. En este sentido, la metodología MAGERIT destaca como una herramienta indispensable y de alto valor estratégico para organizaciones con una profunda dependencia tecnológica, como la Universidad Digital de las Américas (UDA). A diferencia de los marcos de control generalistas, MAGERIT ofrece un enfoque estructurado, matemático y sistemático que permite modelar la realidad operativa de los sistemas de información a través de sus árboles de dependencia de activos.

La importancia de implementar MAGERIT radica en su capacidad para visibilizar el impacto propagado. En un ecosistema donde servicios en la nube, APIs y bases de datos están íntimamente interconectados, esta metodología permite a los responsables de la ciberseguridad comprender con precisión matemática cómo la vulnerabilidad en un componente de infraestructura de nivel inferior puede desencadenar un efecto dominó que comprometa los activos de información de nivel superior, afectando la continuidad de las operaciones del negocio.

Asimismo, **MAGERIT cierra la brecha** existente entre las exigencias normativas de marcos como ISO/IEC 27001 y la ejecución técnica de la seguridad. Mientras que los estándares internacionales definen el "qué se debe proteger", MAGERIT proporciona el "**cómo calcular el riesgo intrínseco y residual**", justificando de manera sólida la inversión en salvaguardas tecnológicas y organizativas. En conclusión, la adopción de este marco permite a la UDA optimizar sus recursos defensivos, priorizar las amenazas de manera realista y construir una postura de resiliencia proactiva capaz de salvaguardar la integridad académica y la continuidad del servicio ante el dinámico panorama de amenazas actuales.